PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Chiffrement, PKI et protocoles de sécurité

09-410 PSE-ER F4-6 Chiffrement, PKI et protocoles de sécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La cryptographie asymétrique utilise un bi-clé pour résoudre le problème de l'échange de secret sans partage préalable.
2. La signature électronique garantit l'intégrité et la non-répudiation en chiffrant l'empreinte avec la clé privée de l'émetteur.
3. L'infrastructure de gestion de clés repose sur des acteurs comme l'autorité de certification qui signe les certificats X509.

Définitions et disciplines

Notion	À retenir
Cryptologie, cryptographie, cryptanalyse	La **cryptologie** est la science du secret. La **cryptographie** conçoit les mécanismes de sécurité. La **cryptanalyse** analyse leur sécurité pour la mettre en défaut. **Décrypter** = sans la clé ; **déchiffrer** = avec. **Chiffre** : substitution de lettres ; **code** : de mots ou phrases.
Les objectifs de sécurité	Objectifs : **confidentialité**, **intégrité**, **authentification** (données ou entités) et **non-répudiation** (empêche de nier une action).

Le chiffrement symétrique

Notion	À retenir
Principe	**Une seule clé** (n bits, 2^n clés possibles) pour chiffrer et déchiffrer ; par **bloc** ou par **flot** ; attaquable par **recherche exhaustive**. DES, 3DES, **AES**, RC4, RC5, MISTY1, Vernam.
Limites	une clé **par paire** d'utilisateurs (difficile à grande échelle) ; **signature** et **non-répudiation** impossibles.

Le chiffrement asymétrique

Notion	À retenir
Principe	Utilisation de clés **publiques** (chiffrement, vérification) et **privées** (déchiffrement, signature) distinctes, reliées par des **équations mathématiques** difficiles à résoudre.
Aspects techniques	**Factorisation** de grands nombres ou **logarithme discret** (ex. **courbes elliptiques**) : difficulté **temporelle**, non prouvée. **RSA**, **DSA** (signature), **Diffie-Hellman** (échange de clés).
Cinématique et apports	Chiffrement avec la **clé publique** du destinataire ; déchiffrement avec sa **clé privée**. Résout le problème de **mise en accord de clé** sans partage préalable de secret.

Résumé : Hachage, Signature et Certificats

Notion	À retenir
Les fonctions de hachage	Convertit une donnée en **empreinte** de taille fixée. Primitives **symétriques**, **non inversibles** et **sans collision**. Algorithmes : `SHA-256` (sûr), `SHA-3` (alternative), `MD5` et `SHA-1` (cassés/non conformes).
La signature électronique	Empreinte chiffrée avec la **clé privée** de l'émetteur. Garantit **identification**, **authentification**, **intégrité** et **non-répudiation**. `SHA-1` et `MD5` sont exclus du panel des fonctions sûres.
Le certificat numérique	Document électronique (**norme X509**) liant une **clé publique** à un propriétaire. Signé par une **autorité de certification** (tiers de confiance). Peut être **renouvelé** ou **révoqué** (via listes **CRL**).

Gestion de l'infrastructure de clés

Notion	À retenir
Cycle de vie clé	Débute par une **demande** ; comprend **génération**, **affectation** (identité/usage), **introduction**, **utilisation**, **fin de vie** (révocation, retrait, destruction) et **renouvellement**. Le **premier enrôlement** repose sur des mesures **physiques et organisationnelles**.
Acteurs IGC	L'**autorité de certification** (tiers de confiance) certifie ; l'**autorité d'enregistrement** contrôle l'identité ; l'**opérateur de certification** distribue et gère le cycle de vie.
Politique certification	Règles définissant l'**usage**, l'**émetteur** et les **conditions** (juridiques, administratives, techniques). Illustrations : **application cliente**, **système de paiement**, **sécurisation poste de travail**.

Protocoles de sécurité

Notion	À retenir
SSH et tunneling	Utiliser **SSH** (pas `telnet`, `rlogin`, `rsh`, `rcp`). Serveur : paire **RSA** (renouvelée **toutes les heures**). Client : clé symétrique chiffrée par clé serveur. Tunneling : redirige flux **TCP** via SSH ou `stunnel` (via **SSL**).
SSL et TCP/IP	Bibliothèque située entre **couche application** et **couche transport**. Garantit **authentification**, **intégrité** et **confidentialité**. Utilisée pour le **HTTPS**.
IPsec	Sécurisation de la couche transport, « protection de niveau 3 ». Contre **spoofing IP**, **vol de session TCP**, **sniffing**. **AH** (authentification) et **ESP** (authentification + chiffrement). Modes **transport**, **tunnel**, **intermédiaire** (machine-passerelle).
Le VPN	Crée un **tunnel chiffré** sur infrastructure publique. Logiciels basés sur **IPsec**, **SSL** ou autres (ex: `OpenVPN`).

Pièges et confusions

⚠ Confondre décrypter (sans la clé) et déchiffrer (avec la clé).
⚠ Croire que la difficulté des problèmes asymétriques est prouvée impossible alors qu'elle est seulement temporelle.
⚠ Penser que la signature numérique résout l'authentification forte des clés publiques sans tiers de confiance.
⚠ Confondre le rôle d'AH (authentification seule) et d'ESP (authentification et chiffrement) dans IPsec.
⚠ Imputer la sécurité du premier enrôlement à la cryptographie alors qu'elle est physique et organisationnelle.

Sigles et définitions

Cryptosystème	algorithme de chiffrement
Condensat	empreinte ou haché, résultat d'une fonction de hachage
Bi-clé	paire formée d'une clé privée et de la clé publique associée
IGC	ensemble de matériels, logiciels, personnes, règles et procédures pour gérer les certificats
CRL	liste signée des certificats révoqués au format X509
Tunneling	encapsulation d'un flux dans un chemin privé

Auto-test

1. Quel algorithme asymétrique repose sur la difficulté de la factorisation ?
2. Quelle est la différence entre un chiffre et un code ?
3. Quelles fonctions de hachage sont considérées comme cassées ou non conformes ?
4. Où se situe la bibliothèque SSL dans le modèle ?
5. Quel protocole assure l'authentification et le chiffrement au niveau réseau ?

Réponses : **1.** RSA · **2.** Le chiffre opère sur les lettres, le code sur les mots ou phrases · **3.** MD5 et SHA-1 · **4.** Entre la couche application et la couche transport · **5.** IPsec (via ESP)

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.